

Layered Internet Protocol Stack

- *Application*: Supporting network applications
 - HTTP, IMAP, SMTP, DNS
- *Transport*: Process-Process data transfer
 - TCP, UDP
- *Network*: Routing of datagrams from source to destination
 - IP, routing protocols
- *Link*: Data transfer between neighboring network elements
 - Ethernet, 802.11 (WiFi), PPP
- *Physical*: Bits “on the wire”

application

transport

network

link

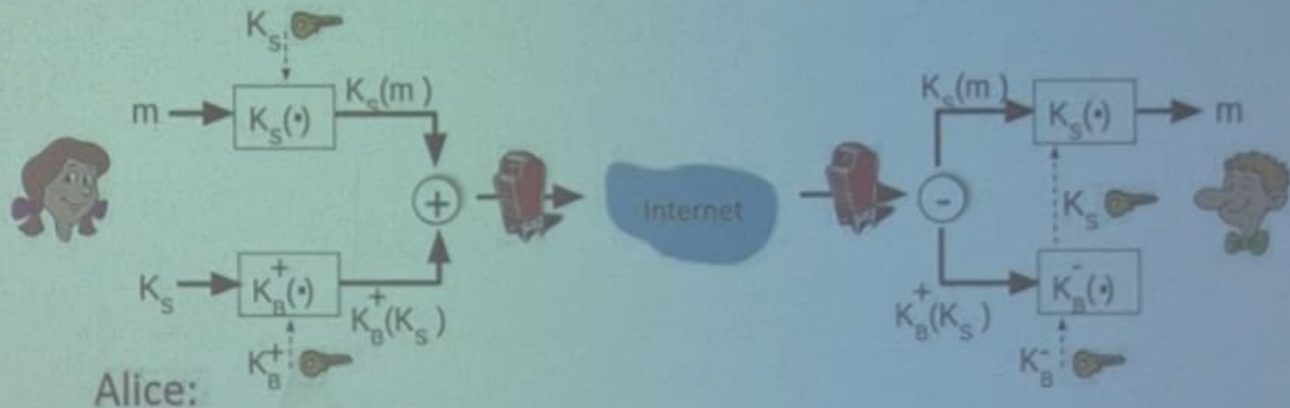
physical

Where to Provide Security?

- A blanket security? - **No user level security**
- All layers? - **Easy to deploy new Internet services at higher layers**

Secure e-mail: Confidentiality

Alice wants to send *confidential* e-mail, m , to Bob

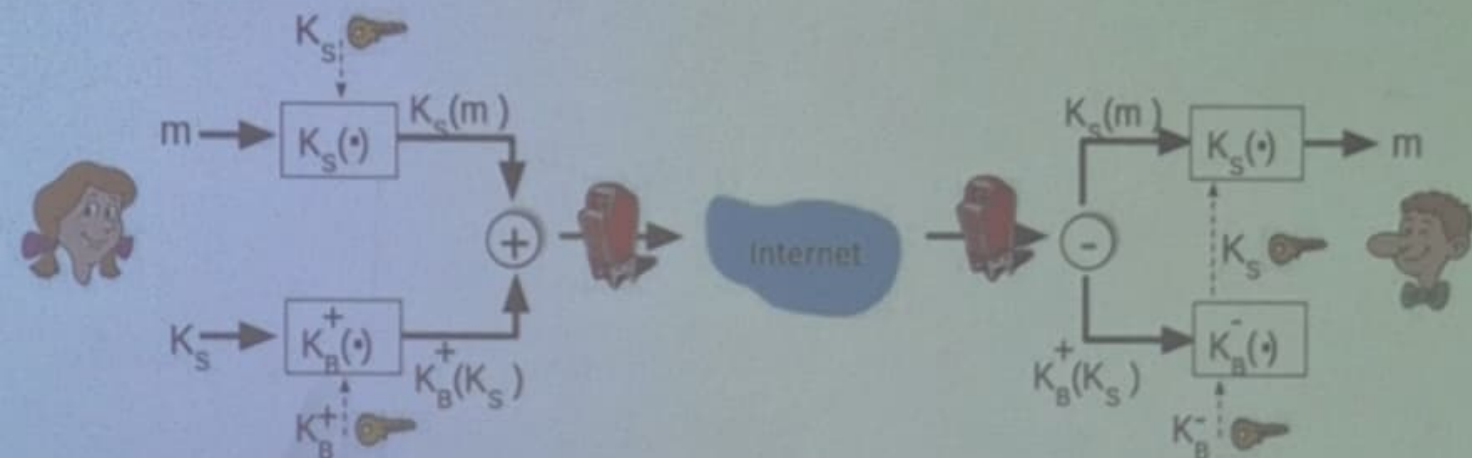


Alice:

- Generates random *symmetric* session key, K_S
- Encrypts message with K_S (for efficiency)
- Encrypts K_S with Bob's public key
- Sends both $K_S(m)$ and $K_B^+(K_S)$ to Bob

Secure e-mail: Confidentiality

Alice wants to send *confidential* e-mail, m , to Bob

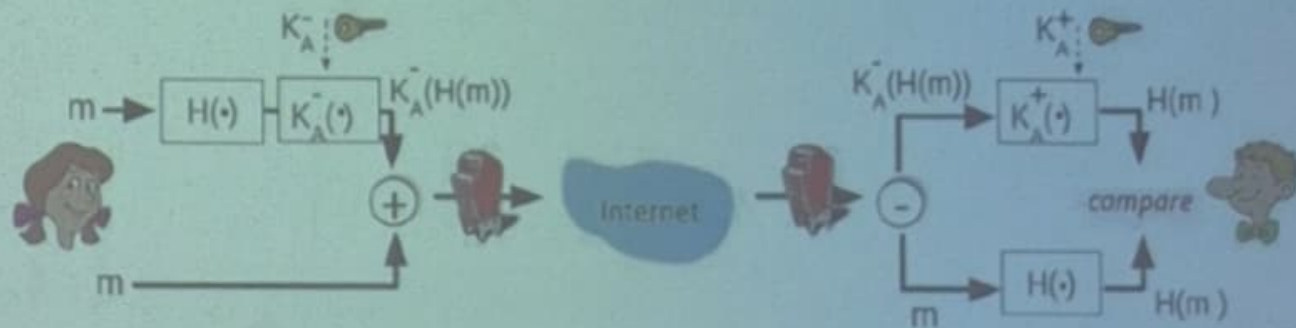


Bob:

- Uses his private key to decrypt and recover K_S
- Uses K_S to decrypt $K_S(m)$ to recover m

Secure e-mail: Integrity, Authentication

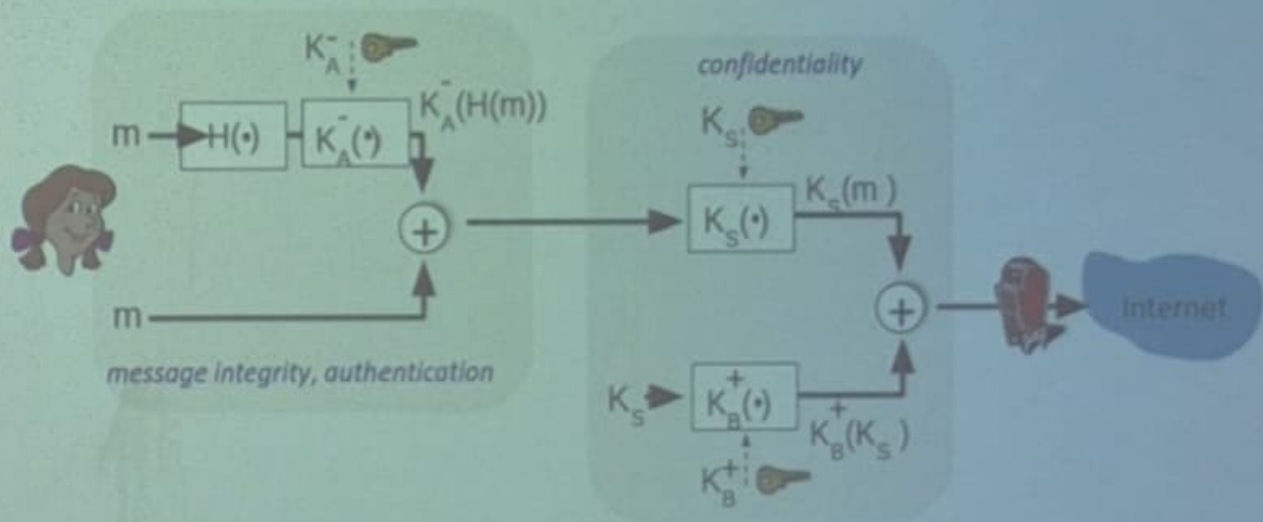
Alice wants to send m to Bob, with *message integrity, authentication*



- Alice digitally signs hash of her message with her private key, providing integrity and authentication
- Sends both message (in the clear) and digital signature

Secure e-mail: Integrity, Authentication

Alice sends m to Bob, with *confidentiality*, *message integrity*, *authentication*



Alice uses three keys: Her private key, Bob's public key, new symmetric key

Transport-Layer Security (TLS)

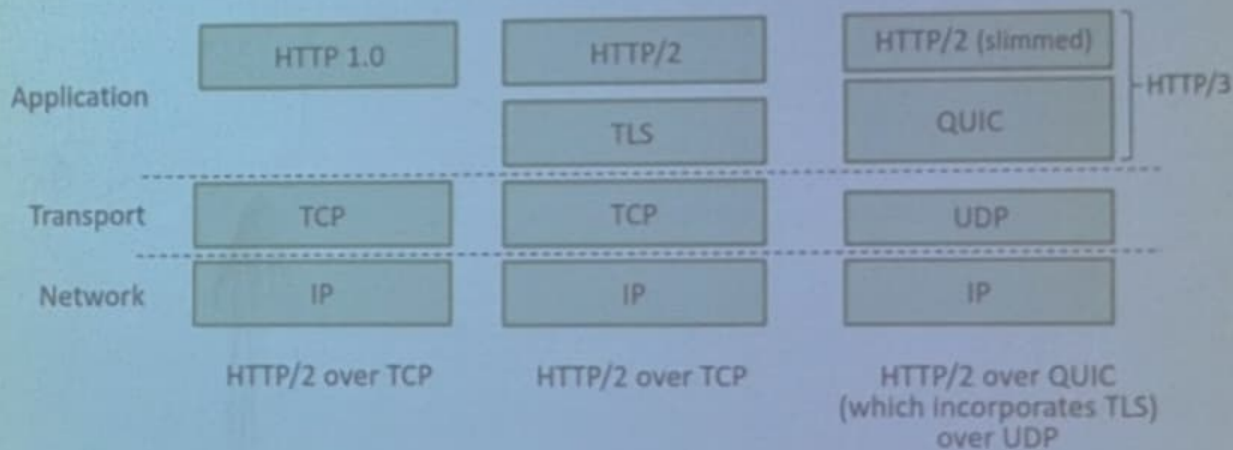
- Widely deployed security protocol above the transport layer
 - Supported by almost all browsers, web servers: https (port 443)
- Provides:
 - Confidentiality: via *symmetric encryption*
 - Integrity: via *cryptographic hashing*
 - Authentication: via *public key cryptography*

Transport-Layer Security: What's Needed?

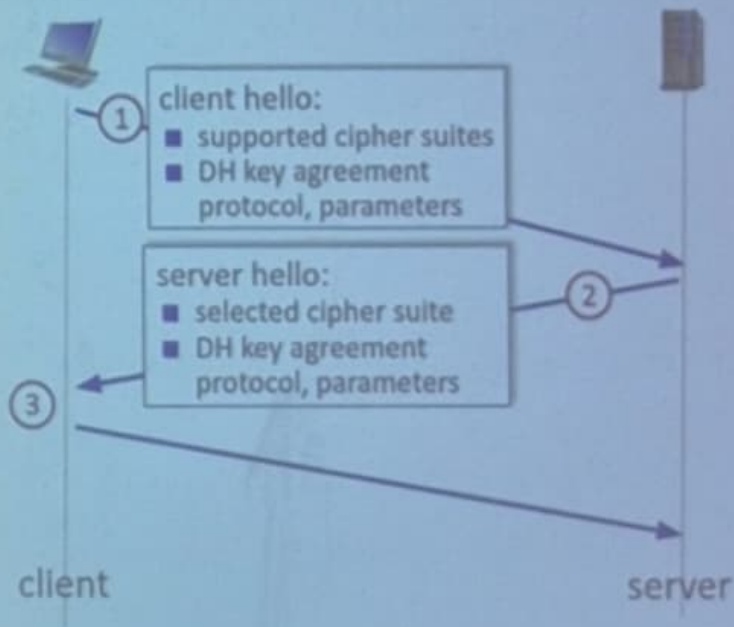
- Handshake: Alice, Bob use their certificates, private keys to authenticate each other, exchange or create shared secret
- Key Derivation: Alice, Bob use shared secret to derive set of keys
- Data Transfer: stream data transfer: data as a series of records
not just one-time transactions
- Connection Closure: special messages to securely close connection

Transport-Layer Security (TLS)

- TLS provides an API that *any* application can use
- An HTTP view of TLS:



TLS 1.3 Handshake



- ① Client TLS hello msg:
 - *guesses* key agreement protocol, parameters
 - indicates cipher suites it supports
- ② Server TLS hello msg chooses
 - key agreement protocol, parameters
 - cipher suite
 - server-signed certificate
- ③ Client:
 - checks server certificate
 - generates key
 - can now make application request (e.g., HTTPS GET)

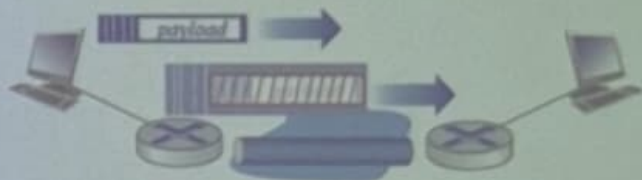
Network Layer Security : IPSec

- Secures IP datagrams between any two network layer entities
- Provides datagram-level encryption, authentication, integrity
 - for both user traffic and control traffic (e.g., BGP, DNS messages)
- Two “modes”: Transport and Tunnel mode



Transport mode:

- *Only* datagram *payload* is encrypted, authenticated

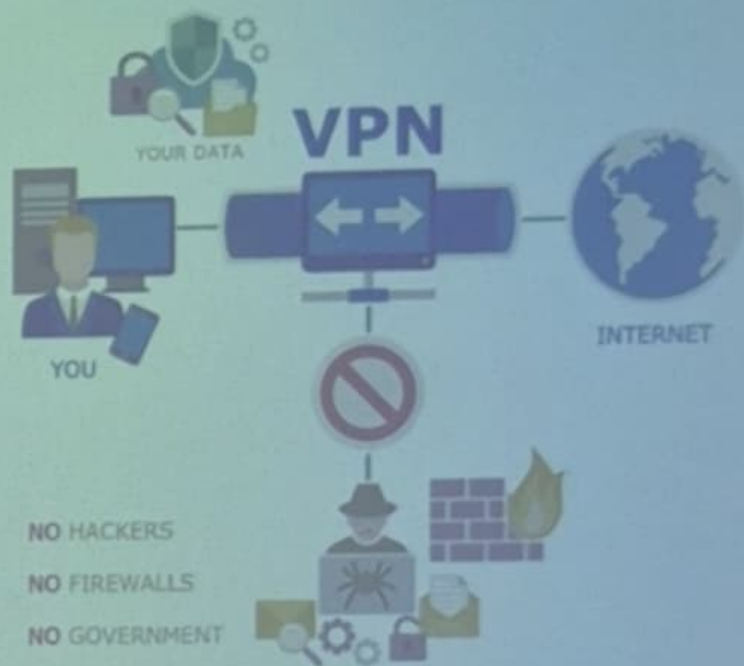


Tunnel mode:

- Entire datagram is encrypted, authenticated
- Encrypted datagram encapsulated in new datagram with new IP header, tunneled to destination

Virtual Private Networks

- VPN encrypts communication over the Internet
- Used for secure remote work and privacy
 - Example: Company employees connecting office system from home

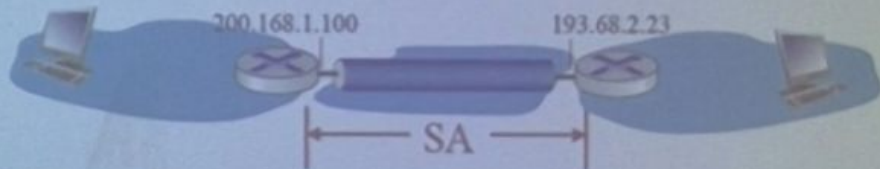


Two IPsec Protocols

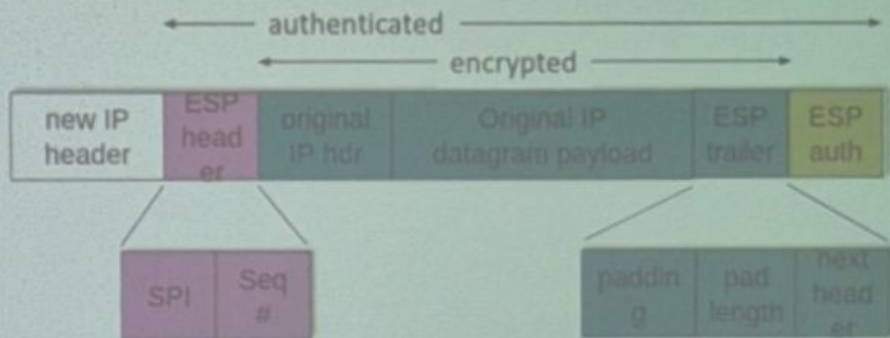
- **Authentication Header (AH) Protocol** [RFC 4302]
 - Provides source authentication & data integrity but *not* confidentiality
- **Encapsulation Security Protocol (ESP)** [RFC 4303]
 - Provides source authentication, data integrity, *and confidentiality*
 - More widely used than AH

Security Associations (SAs)

- Before sending data, Security Association (SA) established from sending to receiving entity (directional)
- Receiving entities maintain *state information* about SA
 - TCP endpoints also maintain state info
 - IP is connectionless; IPsec is connection-oriented!



IPsec Datagram



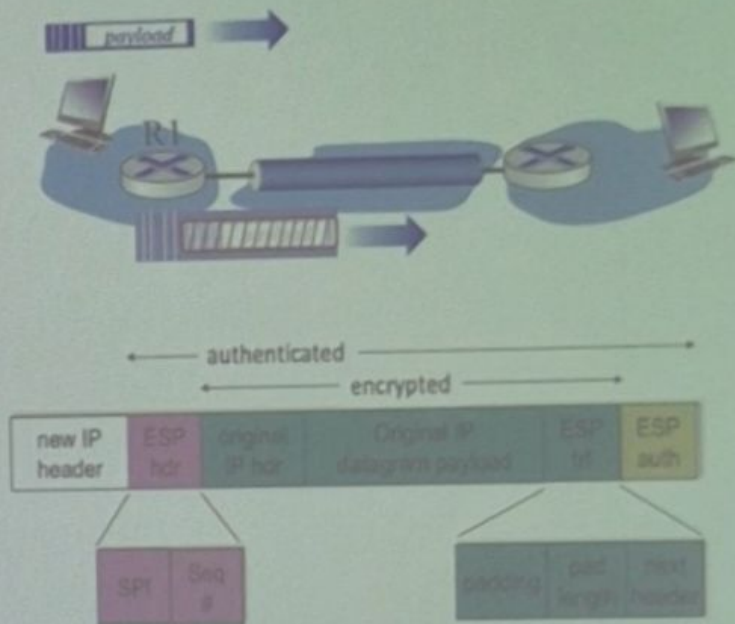
*tunnel mode
ESP*

- ESP trailer: padding for block ciphers
- ESP header:
 - SPI, so receiving entity knows what to do (SPI indicates the SA to which the datagram belongs)
 - Sequence number, to thwart replay attacks
- MAC in ESP auth field created with shared secret key

ESP Tunnel Mode: Actions

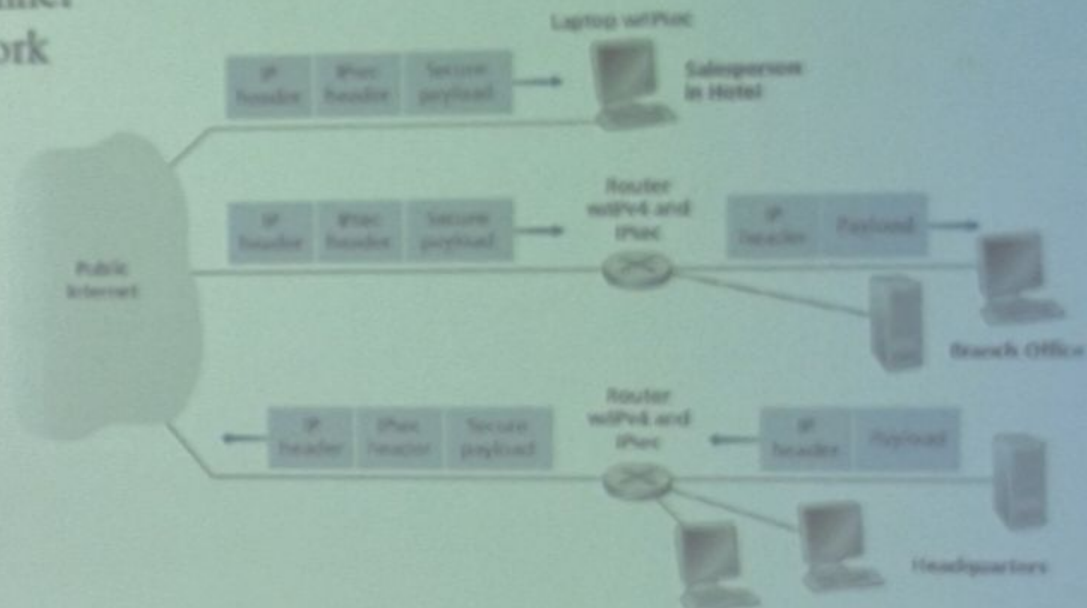
At R1:

- Appends ESP trailer to original datagram (which includes original header fields!)
- Encrypts result using algorithm & key specified by SA
- Appends ESP header to front of this encrypted quantity
- Creates authentication MAC using algorithm and key specified in SA
- Appends MAC forming *payload*
- Creates new IP header, new IP header fields, addresses to tunnel endpoint



Virtual Private Networks

- Creates a secure tunnel over a public network



IPsec Security Databases

Security Policy Database (SPD)

- Policy: For given datagram, sender needs to know if it should use IP sec
- Policy stored in security policy database (SPD)
- Needs to know which SA to use
 - May Use: source and destination IP address; protocol number

SPD: "what" to do

Security Assoc. Database (SAD)

- Endpoint holds SA state in security association database (SAD)
- When sending IPsec datagram, R1 accesses SAD to determine how to process datagram
- When IPsec datagram arrives to R2, R2 examines SPI in IPsec datagram, indexes SAD with SPI, processing datagram accordingly

SAD: "how" to do it

IKE: Internet Key Exchange

- *Previous uses:* Manual establishment of IPsec SAs in IPsec endpoints
- Manual keying is impractical for VPN with 100s of endpoints
- Instead use IPsec IKE (Internet Key Exchange) (RFC 5996)
- IKE helps to create an automated mechanism for creating the SAs
 - Exchange certificates
 - Negotiate authentication and encryption algorithms
 - Securely exchange key material for creating session keys in the IPsec SAs

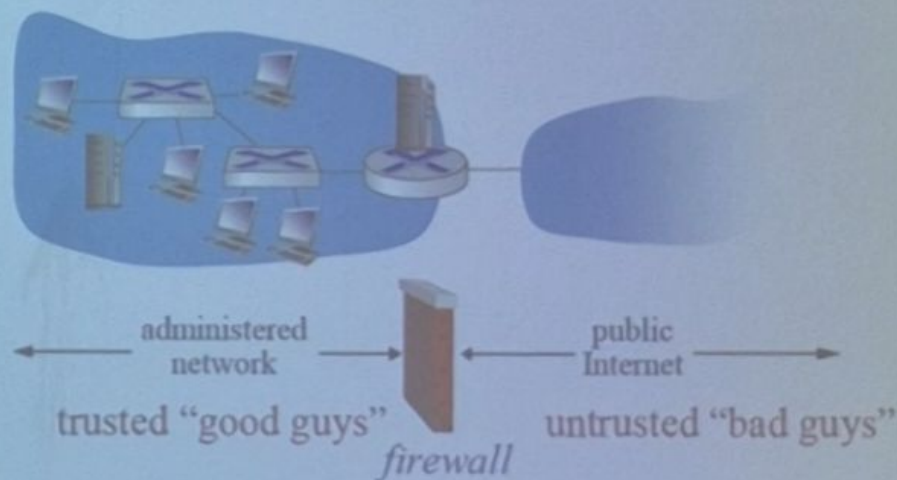
Operational Security

- **Motivation:** To protect sensitive information by managing how data, processes, and daily operations are handled
- **Challenge:** Human errors and routine shortcuts often weaken security controls

Firewalls

Firewall

Isolates organization's internal network - allowing some packets to pass, blocking others



Firewalls: Why?

Prevent Denial of Service Attacks:

- SYN flooding: attacker establishes many bogus TCP connections, no resources left for “real” connections

Prevent illegal modification/access of internal data

- e.g., attacker replaces website homepage with something else

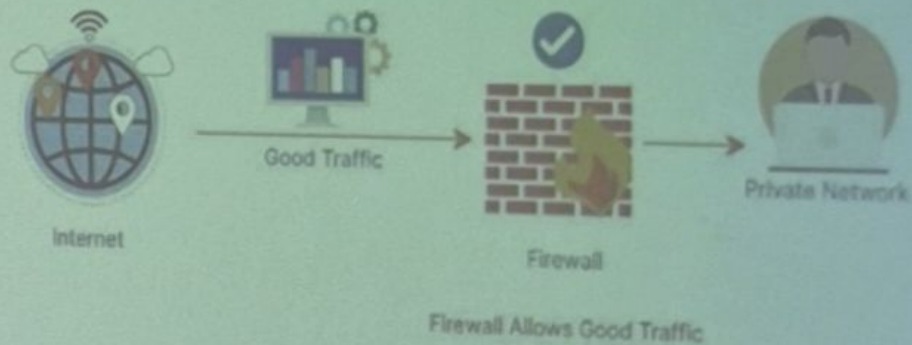
Allow only authorized access to inside network

- Set of authenticated users/hosts

Three goals of Firewalls:

- *All traffic from outside to inside, and vice versa, passes through the firewall*
- *Only authorized traffic, as defined by the local security policy, will be allowed to pass*
- *Firewall itself is immune to penetration*

Types of Firewalls



- **Stateless** – Simple packet filters (checks source/destination)
- **Stateful** – Tracks connections to allow/deny intelligently
- **Application gateway**- filter packets on application data as well as on IP/TCP/UDP fields
- **NGFW (Next-Gen Firewalls)** – Includes intrusion prevention, app filtering, deep inspection

Limitations of Firewalls, Gateways

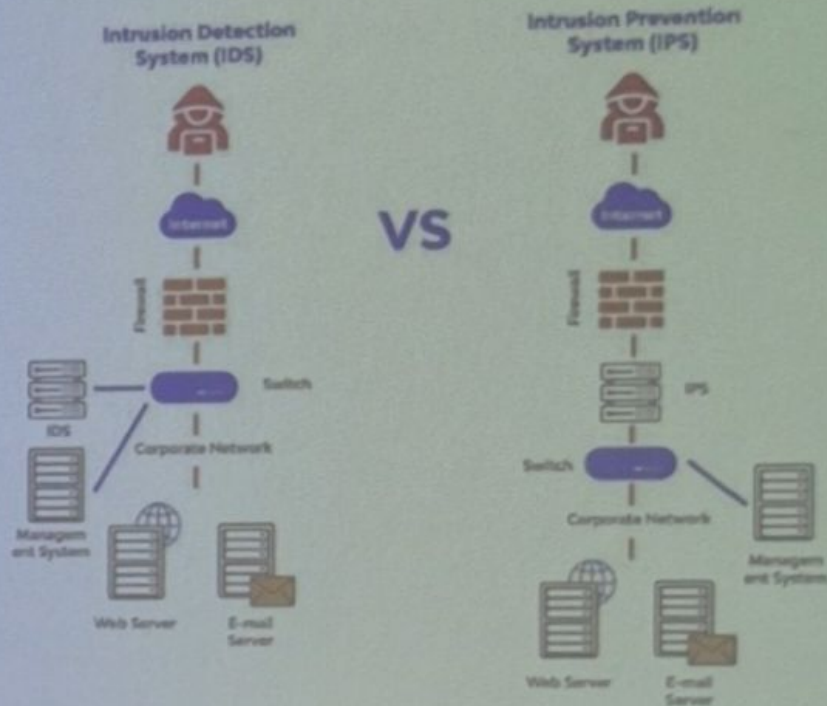
- IP spoofing: router can't know if data "really" comes from claimed source
- If multiple apps need special treatment, each has own app. gateway
- Client software must know how to contact gateway
 - e.g., must set IP address of proxy in Web browser
- *Tradeoff*: degree of communication with outside world, level of security
- Many highly protected sites still suffer from attacks

Intrusion Detection Systems

- Packet Filtering:
 - Operates on TCP/IP headers only
 - No correlation check among sessions
- IDS: Intrusion Detection System
 - Deep packet inspection: look at packet contents (e.g., check character string in packet against database of known virus, attack strings)
 - Examine correlation among multiple packets
 - Port scanning
 - Network mapping
 - DoS attack

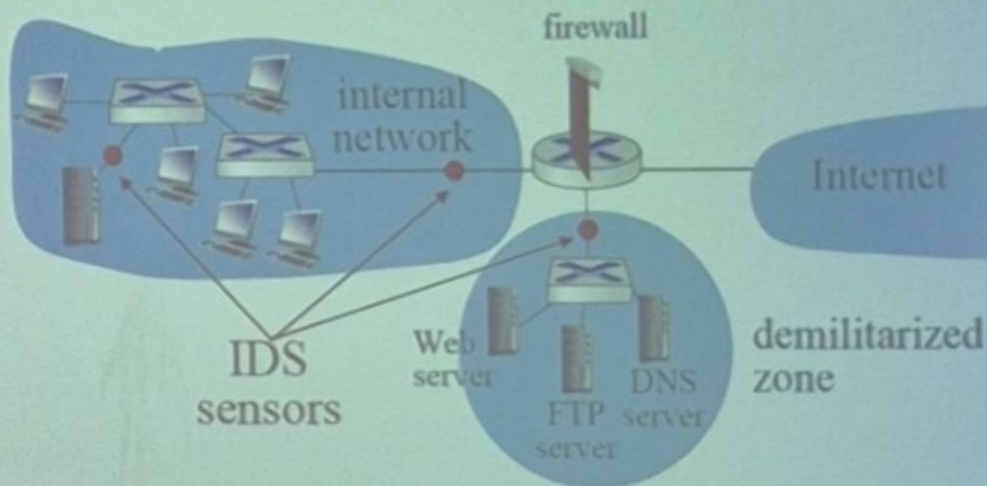
Intrusion Detection vs Prevention Systems (IDS/IPS)

- IDS – Detects suspicious activity, alerts admin
- IPS – Detects **and blocks** suspicious activity
- Helps catch malware, brute force, scanning attempts



Intrusion Detection Systems

Multiple IDSs: Different types of checking at different locations



Security Policies and Practices

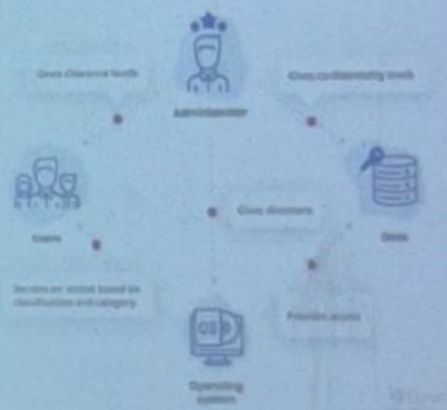


- **Motivation:** To set rules and guidelines that ensure safe use of systems, data, and networks
- **Challenges:** Difficult to enforce consistently because people may ignore or resist policies

Access Control Models

Access control is one of the most essential cybersecurity practices. Meticulous management of user access rights helps to secure sensitive data and reduces the chance of a successful attack.

- **MAC (Mandatory Access Control)**
 - Admin decides who can access

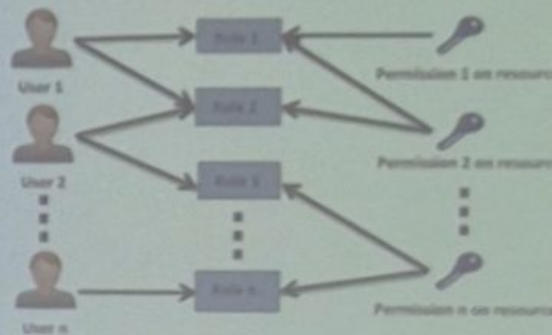


- **DAC (Discretionary Access Control)**
 - Data owner decides permissions



- **RBAC (Role-Based Access Control)**
 - Permissions are tied to roles (e.g., student vs teacher)

Helps balance flexibility vs security in organizations



The Future...

- **Security Policies and Procedures**
 - Formal rules that define how systems are protected
 - Includes password policies, acceptable use, incident response
 - Ensures employees follow consistent security practices



- **Zero Trust Architecture**

Core idea: "Never trust, always verify"

- Every user/device must be authenticated each time they connect
- Useful in cloud and remote work settings



- **Defense in Depth Computing**

- Security is layered – if one fails, others still protect
- Example: Firewall + IDS + antivirus + backups
- Prevents single point of failure

